

NanoAudit - Reporte Tecnico

INFORME TECNICO DE AUDITORIA

=====

Auditor: Ing.Ángel G. Castillo G.

Fecha: 2026-02-02 18:25:29

Modulo: Auditoria Red

=====

INFORME DE AUDITORIA DE RED

Fecha: 22 de mayo de 2024

Consultor: Consultor Senior en Ciberseguridad

OBJETIVO:

Analizar la información de puertos de red proporcionada para identificar posibles vulnerabilidades, evaluar el impacto en el negocio y proponer soluciones de mitigación.

1. ANALISIS TECNICO: Que se encontro.

Se ha realizado un análisis de la información de puertos expuestos de un sistema o segmento de red. La ausencia de información sobre el estado de los puertos (abierto, filtrado, cerrado) y los servicios específicos (a excepción de Unbound en el puerto 53) limita la profundidad del análisis, obligando a inferencias basadas en asignaciones estándar.

Puertos Identificados:

NanoAudit - Reporte Tecnico

- Port 21 (FTP): Puerto estándar para el Protocolo de Transferencia de Archivos. Si está abierto y en uso, es común que se transmita información (incluyendo credenciales) en texto plano, a menos que se implemente FTPS o SFTP. La falta de información sobre el servicio exacto impide determinar el nivel de seguridad actual.

- Port 22 (SSH): Puerto estándar para Secure Shell. Permite el acceso remoto seguro a sistemas. Su presencia es esperada para administración, pero su configuración (autenticación, usuarios permitidos, etc.) es crítica para la seguridad.

- Port 23 (Telnet): Puerto estándar para Telnet. Este protocolo es conocido por transmitir toda la información, incluidas las credenciales de acceso, en texto plano. Se considera un protocolo obsoleto y altamente inseguro para el acceso remoto.

- Port 53 (DNS): Se identificó el servicio "Unbound". Unbound es un servidor de resolución de DNS moderno y recursivo, valorado por su seguridad y privacidad. Sin embargo, su configuración es vital; si actúa como un resolver DNS abierto, puede ser abusado para ataques de amplificación DDoS o para proporcionar información interna a agentes externos.

- Port 80 (HTTP): Puerto estándar para el Protocolo de Transferencia de Hipertexto. Se utiliza para la comunicación web no cifrada. La presencia de este puerto indica que puede haber servicios web accesibles sin cifrado, lo que expone los datos en tránsito.

- Port 443 (HTTPS): Puerto estándar para HTTP Seguro. Se utiliza para la comunicación web cifrada mediante TLS/SSL. Su presencia es positiva, indicando la posibilidad de servicios web seguros, pero la configuración TLS (versiones, suites de cifrado, calidad del certificado) debe ser auditada.

- Port 5431: Este puerto no corresponde a un servicio estándar ampliamente conocido. Su presencia es inusual y requiere una investigación inmediata para identificar el servicio exacto que lo está utilizando. Podría ser una aplicación personalizada, un servicio de base de datos no estándar (ej. PostgreSQL usa 5432), o incluso una actividad maliciosa.

NanoAudit - Reporte Tecnico

2. IMPACTO: Riesgo para el negocio.

La presencia de ciertos puertos y la falta de detalle en la información representa riesgos significativos para la postura de seguridad y la continuidad del negocio:

- Riesgo de Acceso No Autorizado y Compromiso del Sistema (CRITICO):

- Port 23 (Telnet): La exposición de Telnet es una vulnerabilidad crítica. Cualquier atacante con capacidad de intercepción de tráfico de red puede capturar credenciales de acceso (nombre de usuario y contraseña) en texto plano. Esto puede llevar a un acceso completo y no autorizado al sistema, con el consiguiente robo de datos, instalación de malware, interrupción de servicios y pérdida de control.

- Port 5431 (Puerto Desconocido): La existencia de un servicio en un puerto no estándar y no identificado es una alerta roja. Podría tratarse de un backdoor, un servicio malicioso, una aplicación vulnerable o un error de configuración. Sin identificación, no se puede evaluar su seguridad, monitorear su actividad o asegurar que no esté siendo explotado. Representa un punto ciego de seguridad que puede ser el vector de un ataque serio.

- Riesgo de Exposición de Datos Sensibles (ALTO):

- Port 21 (FTP): Si se usa FTP sin cifrado (FTPS/SFTP), cualquier dato transferido, incluyendo información confidencial o credenciales de usuarios, es vulnerable a la intercepción.

- Port 80 (HTTP): Si se sirve contenido web en HTTP sin redirección a HTTPS, la información transmitida (credenciales de inicio de sesión, datos personales, formularios) puede ser interceptada en texto plano por atacantes en la misma red o en el camino.

- Riesgo de Denegación de Servicio y Abuso de Recursos (MEDIO):

- Port 53 (Unbound DNS): Si Unbound está configurado como un resolver DNS abierto (accesible desde

NanoAudit - Reporte Tecnico

cualquier parte de internet), puede ser abusado por actores maliciosos para participar en ataques de amplificación DDoS contra terceros, lo que consume recursos de red y CPU del servidor y puede llevar a la inclusión en listas negras. También puede ser susceptible a ataques de envenenamiento de caché si no está configurado correctamente.

- Riesgo de Cumplimiento y Reputación (ALTO):

- La operación de servicios inseguros como Telnet o la exposición de datos no cifrados puede violar normativas de protección de datos (ej. GDPR, HIPAA) y estándares de seguridad de la industria. Un incidente resultante de estas vulnerabilidades puede causar daños significativos a la reputación de la organización, multas regulatorias y pérdida de confianza de clientes y socios.

- Riesgo General de Gestión de la Postura de Seguridad (ALTO):

- La falta de inventario detallado de servicios y la presencia de puertos desconocidos sugieren deficiencias en la gestión de activos y la visibilidad de la red, lo que dificulta la identificación proactiva y la mitigación de riesgos.

3. SOLUCION: Comandos o pasos de mitigacion.

Es imperativo abordar estas vulnerabilidades con urgencia. Se recomiendan las siguientes acciones:

A. ACCIONES DE MITIGACION CRITICAS E INMEDIATAS:

1. Deshabilitar y Eliminar Telnet (Port 23):

- Identificar y eliminar el servicio Telnet de cualquier sistema donde esté activo.
- En sistemas Linux/Unix:

NanoAudit - Reporte Tecnico

```
sudo systemctl stop telnet.socket
```

```
sudo systemctl disable telnet.socket
```

```
sudo apt-get remove telnetd (Debian/Ubuntu)
```

```
sudo yum remove telnet-server (CentOS/RHEL)
```

- En sistemas Windows: Desinstalar la característica de Servidor Telnet a través del Administrador del Servidor.

- Sustituir por SSH para acceso remoto seguro.

2. Identificar y Asegurar/Bloquear el Puerto 5431:

- Realizar una investigación forense inmediata para determinar qué servicio está escuchando en el puerto 5431.

En Linux: `sudo lsof -i :5431` o `sudo netstat -tulnp | grep 5431`

En Windows: `netstat -ano | findstr :5431` y luego `tasklist | findstr <PID>`

- Si el servicio es desconocido, no autorizado o malicioso:

- Bloquear inmediatamente el puerto 5431 en el firewall del host y en cualquier firewall perimetral.

- Investigar la causa raíz de su presencia (compromiso, instalación no autorizada).

- Si es un servicio legítimo y necesario:

- Documentar su propósito y propietario.

- Asegurarlo aplicando principios de mínimo privilegio, autenticación fuerte y cifrado.

- Restringir el acceso en el firewall solo a IPs autorizadas.

B. ACCIONES DE MITIGACION ESTANDAR Y MEJORA:

1. Fortalecer Acceso SSH (Port 22):

- Deshabilitar la autenticación por contraseña:

NanoAudit - Reporte Tecnico

Editar /etc/ssh/sshd_config y configurar PasswordAuthentication no.

- Usar autenticación basada en claves SSH.
- Restringir usuarios y IPs permitidas:

Configurar AllowUsers y AllowGroups en /etc/ssh/sshd_config.

Configurar reglas de firewall para permitir solo IPs de administración conocidas.

- Considerar cambiar el puerto SSH a uno no estándar (ej. Port 2222) para reducir escaneos automatizados, aunque no es una medida de seguridad primaria.
- Habilitar autenticación multifactor (MFA) si es posible.

2. Asegurar el Servicio FTP (Port 21):

- Si el servicio FTP no es estrictamente necesario, deshabilitarlo o eliminarlo.

```
sudo systemctl stop <ftp_service>
```

```
sudo systemctl disable <ftp_service>
```

```
sudo apt-get remove <ftp_package>
```

- Si es indispensable, migrar a SFTP (SSH File Transfer Protocol) o FTPS (FTP Secure) y asegurarse de que el cifrado esté activado por defecto.

- Implementar autenticación fuerte y gestionar los permisos de usuario con el principio de mínimo privilegio.

3. Configurar Unbound DNS (Port 53):

- Asegurarse de que Unbound NO actúe como un resolver DNS abierto:

Restringir las consultas a la red interna o a IPs específicas.

Ejemplo en unbound.conf: access-control: 192.168.1.0/24 allow

- Habilitar DNSSEC para validar respuestas DNS.
- Implementar rate limiting para prevenir ataques de amplificación.

NanoAudit - Reporte Tecnico

- Mantener Unbound y el sistema operativo actualizados.

4. Implementar HTTPS y Redirección (Port 80 y 443):

- Para servicios web en Port 80 (HTTP):
 - Configurar redirección 301 (permanente) de HTTP a HTTPS para todo el tráfico.
 - Implementar HTTP Strict Transport Security (HSTS) para forzar el uso de HTTPS por parte de los navegadores.
- Si no hay servicio web, bloquear el puerto 80 en el firewall.
- Para servicios web en Port 443 (HTTPS):
 - Asegurarse de utilizar versiones robustas de TLS (TLS 1.2 o superior).
 - Configurar suites de cifrado fuertes y deshabilitar las débiles.
 - Verificar la validez y actualidad del certificado SSL/TLS.

C. RECOMENDACIONES GENERALES DE SEGURIDAD:

- Inventario de Activos: Mantener un inventario actualizado de todos los servicios y puertos en la red, junto con su propósito y propietario.
- Políticas de Firewall: Implementar políticas de firewall de "denegación por defecto", permitiendo explícitamente solo el tráfico necesario.
- Gestión de Parches: Establecer un proceso robusto de gestión de parches para mantener todos los sistemas operativos y aplicaciones actualizados.
- Escaneo de Vulnerabilidades: Realizar escaneos de vulnerabilidades periódicos en toda la infraestructura de red.
- Auditorías de Seguridad: Programar auditorías de seguridad periódicas para verificar la configuración y el cumplimiento de las políticas.

NanoAudit - Reporte Tecnico

- Monitoreo y Logging: Implementar un sistema centralizado de gestión de logs (SIEM) para monitorear la actividad en estos puertos y servicios, alertando sobre comportamientos anómalos.
- Segmentación de Red: Segmentar la red para limitar el impacto de un posible compromiso.

Estas acciones reducirán significativamente el perfil de riesgo de la red y mejorarán su postura de seguridad.

Es crucial priorizar las acciones críticas para Telnet y el puerto desconocido (5431).

=====